Implement and manage Zero Trust Network Access (ZTNA) using Zscaler by enabling secure, identity-based user-to-application connectivity without exposing internal networks

Team ID: SWTID-2026-5960.

College Code: bru26.

List of teammates:5

S.no	Name	Collage	Mail ID
01	Archana S	Shri Nehru Maha Vidyalaya College of Arts & Science	archana8sekar@gmail.com
02	Adithya A	Shri Nehru Maha Vidyalaya College of Arts & Science	adithyaarumugam5697@gmail.com
03	Sivaranjan S	Shri Nehru Maha Vidyalaya College of Arts & Science	sivaranjan9707@gmail.com
04	Sanjay Kumar R	Shri Nehru Maha Vidyalaya College of Arts & Science	sanjaysanjay638041@gmail.com
05	Harshitha C	Shri Nehru Maha Vidyalaya College of Arts & Science	harshithac096@gmail.com

1. Introduction

In today's rapidly evolving digital landscape, organizations are increasingly adopting cloud technologies, remote work environments, and mobile devices to improve productivity and flexibility. However, this transformation has also expanded the attack surface for cyber threats, making traditional network security models less effective. Conventional security approaches such as Virtual Private Networks (VPNs) and perimeter-based defenses assume that once a user gains access to the network, they can be trusted. This model is no longer sufficient in a world where users, devices, and applications are distributed across multiple locations and environments. As a result, modern cybersecurity strategies are shifting toward the **Zero Trust security model**, which operates on the principle of **"never trust, always verify."**

Zero Trust Network Access (ZTNA) is an essential component of the Zero Trust architecture. It is designed to provide secure, identity-based access to applications without exposing the entire network. Instead of granting users broad network access, ZTNA ensures that users are only allowed to connect to specific applications after proper authentication and authorization. This approach significantly reduces the risk of unauthorized access, data breaches, and lateral movement within the network. By continuously verifying user identity, device health, and access policies, ZTNA helps organizations maintain a higher level of security while enabling seamless connectivity.

One of the leading solutions in implementing Zero Trust Network Access is **Zscaler**, a cloud-native security platform that provides secure access to applications and services without relying on traditional network infrastructure. Zscaler delivers ZTNA through its **Zscaler Private Access (ZPA)** service, which allows users to connect securely to internal applications hosted in data centers or cloud environments. Unlike VPNs that connect users directly to the network, Zscaler establishes a secure, encrypted connection between the user and the application, ensuring that the network itself remains hidden and protected.

The core idea behind Zscaler's ZTNA approach is to create a **direct, secure, and policy-based connection** between the user and the application. When a user attempts to access an application, Zscaler verifies the user's identity, device posture, and security policies before granting access. If the request meets the predefined security requirements, Zscaler dynamically connects the user to the specific application without exposing the broader network. This architecture eliminates the risk of network-level attacks and ensures that only authorized users can access critical resources.

Another key advantage of ZTNA with Zscaler is its **cloud-based architecture**, which provides scalability, flexibility, and improved performance. Since the service operates through a globally distributed cloud platform, users can securely access applications from anywhere in the world without experiencing performance issues commonly associated with traditional VPNs. This is particularly beneficial for organizations with remote or hybrid work environments, where employees need secure access to corporate resources from different locations and devices.

Furthermore, Zscaler enhances security by incorporating advanced features such as **continuous authentication, device posture checks, micro-segmentation, and real-time**

monitoring. Continuous authentication ensures that users are verified not only during login but throughout the entire session. Device posture checks confirm that the user's device meets security standards, such as having updated antivirus software or operating system patches. Micro-segmentation restricts access to specific applications, preventing attackers from moving laterally within the network even if they compromise a user account.

The adoption of Zero Trust Network Access is becoming increasingly important as cyber threats continue to grow in complexity and frequency. Organizations face risks such as ransomware attacks, phishing campaigns, insider threats, and unauthorized access attempts. By implementing ZTNA with Zscaler, companies can significantly reduce these risks by ensuring that every access request is verified and controlled. This not only strengthens security but also improves compliance with regulatory standards and data protection policies.

In addition to improving security, ZTNA with Zscaler also simplifies network management. Traditional VPN infrastructure requires complex configuration, hardware maintenance, and constant monitoring. In contrast, Zscaler's cloud-delivered platform eliminates the need for on-premises hardware and reduces operational overhead. Security policies can be managed centrally, allowing administrators to easily control access to applications and monitor user activity across the organization.

Overall, Zero Trust Network Access with Zscaler represents a modern approach to securing user-to-application connectivity in a highly distributed digital environment. By replacing outdated perimeter-based security models with identity-driven access control, organizations can protect sensitive data, prevent unauthorized access, and ensure secure connectivity for users regardless of their location. As businesses continue to adopt cloud computing and remote work models, solutions like Zscaler ZTNA play a crucial role in building a secure and resilient cybersecurity framework.

Abstract:

The rapid growth of cloud computing, remote work, and mobile device usage has significantly changed the way organizations access and manage their digital resources. Traditional security models that rely on a fixed network perimeter are no longer sufficient to protect modern IT environments. These traditional approaches often assume that users inside the network can be trusted, which creates security vulnerabilities and increases the risk of cyberattacks. To address these challenges, organizations are increasingly adopting the **Zero Trust security model**, which operates on the principle of continuously verifying every user and device before granting access to applications or data.

Zero Trust Network Access (ZTNA) is a key technology that implements the Zero Trust model by providing secure, identity-based access to applications rather than granting full network access. Unlike traditional Virtual Private Networks (VPNs), ZTNA connects users directly to specific applications after verifying their identity, device security status, and access permissions. This approach reduces the risk of unauthorized access and limits the ability of attackers to move laterally within the network. By ensuring that only authenticated and authorized users can access specific resources, ZTNA strengthens overall network security.

One of the leading platforms that delivers ZTNA solutions is **Zscaler**, a cloud-native security service designed to provide secure and scalable user-to-application connectivity. Zscaler's Zero Trust Network Access solution, known as **Zscaler Private Access (ZPA)**, enables organizations to securely connect users to internal applications without exposing the underlying network infrastructure. By establishing secure, encrypted connections between users and applications, Zscaler ensures that sensitive corporate resources remain protected from external threats.

The Zscaler ZTNA architecture uses a cloud-based platform to authenticate users, enforce security policies, and create a secure connection between the user and the requested application. This process involves multiple security checks such as user identity verification, device posture validation, and policy enforcement. Additionally, the platform supports micro-segmentation, which restricts user access to only the applications they are authorized to use. This greatly minimizes the potential impact of security breaches and improves the overall security posture of an organization.

In conclusion, Zero Trust Network Access with Zscaler represents a modern and effective approach to securing user-to-application connectivity in today's distributed IT environments. By replacing traditional network-based security with identity-driven access control, ZTNA improves security, enhances user experience, and simplifies network management. As cyber threats continue to evolve and organizations increasingly rely on cloud and remote work technologies, implementing ZTNA solutions such as Zscaler becomes essential for maintaining strong and reliable cybersecurity.

Use Case Scenarios:

Scenario 1: Secure Remote Employee Access

Employees working from home need to securely access internal company applications without exposing the entire network.

Output:

1. Employees can securely access internal applications from any location.
2. Only authorized users are allowed to connect to specific applications.
3. Company network infrastructure remains hidden from external users.
4. Risk of unauthorized access and cyber attacks is significantly reduced.

Scenario 2: Secure Access for Third-Party Vendors

Organizations often allow external vendors or partners to access specific internal systems for maintenance or collaboration.

Output:

1. Vendors are granted access only to required applications.
2. Unauthorized access to other company resources is prevented.

3. Access permissions can be easily controlled and monitored.
4. Security risks from third-party access are minimized.

Scenario 3: Protection Against Insider Threats

An employee or compromised account attempts to access sensitive applications beyond their permission.

Output:

1. Access is restricted based on user identity and role.
2. Unauthorized attempts to access restricted applications are blocked.
3. Continuous authentication ensures secure session monitoring.
4. Insider threats and data breaches are reduced.

Scenario 4: Secure Cloud Application Access

Organizations using cloud applications need secure and controlled access for employees.

Output:

1. Users securely access cloud applications without VPN dependency.
2. Application access is controlled through identity verification.
3. Data transfer between user and application remains encrypted.
4. Cloud resources remain protected from external threats.

Scenario 5: Secure Access from Untrusted Devices

Employees may attempt to access company applications using personal or unmanaged devices.

Output:

1. Device posture checks ensure only secure devices can access applications.
2. Untrusted or non-compliant devices are automatically blocked.
3. Security policies enforce safe device usage.
4. Overall system security and data protection are improved.

Stage – 1

Title of the project:

Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Overview:

Zero Trust Network Access (ZTNA) is a modern security model that replaces traditional network security methods such as VPNs. Instead of trusting users or devices simply because they are inside the corporate network, ZTNA follows the principle of **"never trust, always verify."** This approach ensures that every user, device, and application request is continuously authenticated and authorized before access is granted. By implementing ZTNA, organizations can protect sensitive resources from unauthorized access, cyber threats, and data breaches.

Zscaler is a cloud-based security platform that enables organizations to implement the Zero Trust model effectively. Zscaler's ZTNA solution connects users directly to specific applications instead of the entire network, which significantly reduces the attack surface. This means that users only access the applications they are permitted to use, while the rest of the network remains hidden. Because Zscaler operates through the cloud, it provides secure access for users working from offices, homes, or remote locations without requiring traditional VPN connections.

ZTNA with Zscaler works by verifying multiple factors before granting access to an application. These factors include **user identity, device security posture, application sensitivity, and contextual information** such as location or time of access. Once the verification is completed, a secure connection is established between the user and the specific application. This method ensures that only authorized users with trusted devices can access corporate resources, improving overall security and reducing the risk of cyber attacks.

In modern organizations where remote work and cloud applications are common, ZTNA with Zscaler plays a crucial role in protecting digital infrastructure. It provides **secure, scalable, and efficient user-to-application connectivity** without exposing the internal network to potential threats. By adopting this Zero Trust approach, organizations can enhance their cybersecurity posture while maintaining seamless and secure access for employees, partners, and stakeholders.

Zero Trust Network Access with **Zscaler** also improves network performance and simplifies security management. Since the platform is delivered through the cloud, organizations do not need to maintain complex hardware-based security systems or traditional VPN infrastructure. Zscaler routes user traffic through its secure cloud gateway, where security policies, threat

detection, and data protection measures are applied before allowing access to applications. This centralized security approach helps organizations manage policies more efficiently while ensuring consistent protection across all users and devices.

Additionally, ZTNA with Zscaler supports modern digital transformation by enabling secure access to both on-premise and cloud-based applications. As businesses increasingly adopt cloud services and remote work environments, traditional security models struggle to provide adequate protection. Zscaler's Zero Trust architecture ensures that applications remain hidden from the public internet and are accessible only through authenticated connections. This not only strengthens cybersecurity but also ensures a seamless and secure user experience for employees accessing critical business applications from anywhere.

List of Vulnerability Table:

S.NO	Category Name	Vulnerability Name	CWE/CVE – No
1	Broken Access Control	Exposure of Sensitive Information to an Unauthorized Actor	CWE-200
2	Security Misconfiguration	Password in Configuration File	CWE-260
3	Software Supply Chain Failures	Reliance on Component That is Not Updateable	CWE-1329
4	Cryptographic Failures	Use of a Key Past its Expiration Date	CWE-324
5	Injection	Improper Control of Resource Identifiers ('Resource Injection')	CWE-99
6	Insecure Design	Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')	CWE-444

7	Authentication Failures	Unverified Password Change	CWE-620
8	Software or Data Integrity Failures	Insufficient Verification of Data Authenticity	CWE-345
9	Security Logging and Alerting Failures	Insufficient Logging	CWE-778
10	Mishandling of Exceptional Conditions	Divide By Zero	CWE-369

REPORT:-

1.

Vulnerability Name:- Exposure of Sensitive Information to an Unauthorized Actor

CWE/CVE : - CWE-200

OWASP/SANS Category:- A01:2025 Broken Access Control

Description:- This vulnerability occurs when an application exposes sensitive information to users who are not authorized to access it. Sensitive data such as personal information, authentication tokens, API keys, database credentials, system configuration details, or internal files may be visible due to improper access control mechanisms.

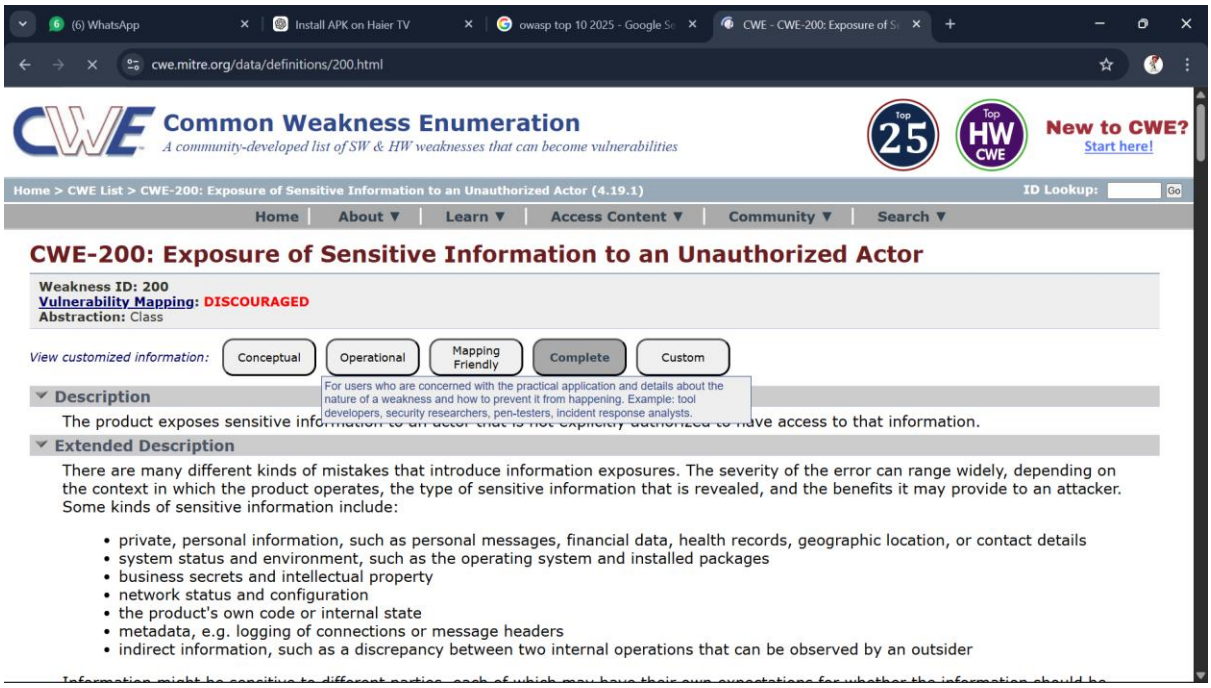
This can happen when access restrictions are not properly implemented, when endpoints are accessible without authentication, or when sensitive data is included in API responses, logs, or error messages. Attackers may exploit this weakness by directly accessing restricted resources, modifying request parameters, or viewing hidden information through insecure APIs or misconfigured permissions.

As a result, unauthorized users can gain access to confidential data that should normally be protected by authentication and authorization controls.

Business Impact::- If sensitive information is exposed, attackers may obtain confidential data belonging to the organization or its users. This can lead to data breaches, identity theft, and unauthorized access to internal systems.

Exposure of sensitive information can also damage the organization's reputation, reduce customer trust, and lead to financial losses. In some cases, the organization may face legal or regulatory penalties if the exposed data includes personal or protected information.

Additionally, attackers may use the leaked data to launch further attacks such as account takeover, system compromise, or privilege escalation.



2.

Vulnerability Name:- Password in Configuration File

CWE/CVE : - CWE-260

OWASP/SANS Category:- A02:2025 Security Misconfiguration

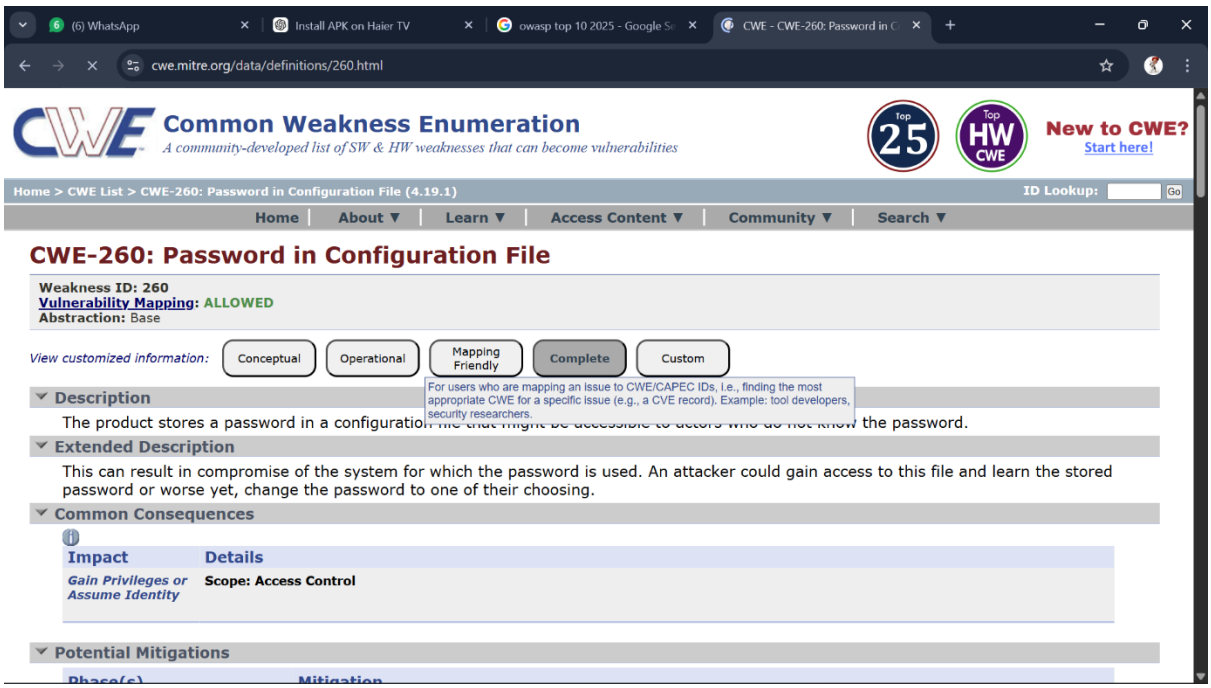
Description:- This vulnerability occurs when passwords or sensitive credentials are stored directly in configuration files in plain text. Configuration files are commonly used to store application settings such as database connection details, API keys, and authentication credentials.

If these files are not properly secured, attackers or unauthorized users may gain access to them through misconfigured servers, exposed repositories, backup files, or directory listing. Because the password is stored in plain text without encryption or secure protection, anyone who accesses the configuration file can easily read and misuse the credentials.

Storing passwords in configuration files without proper security controls increases the risk of unauthorized access to databases, applications, and internal systems.

Business Impact::- If attackers obtain passwords from configuration files, they may gain unauthorized access to critical systems such as databases, administrative accounts, or backend services. This can lead to data breaches, data manipulation, or complete system compromise.

Exposure of credentials may also allow attackers to escalate privileges within the system and perform malicious actions. This can result in financial losses, service disruption, and damage to the organization's reputation. In addition, organizations may face legal and compliance issues if sensitive user data is exposed due to weak credential management practices.



3.

Vulnerability Name:- Reliance on Component That is Not Updateable

CWE/CVE : - CWE-1329

OWASP/SANS Category:- A03:2025 Software Supply Chain Failures

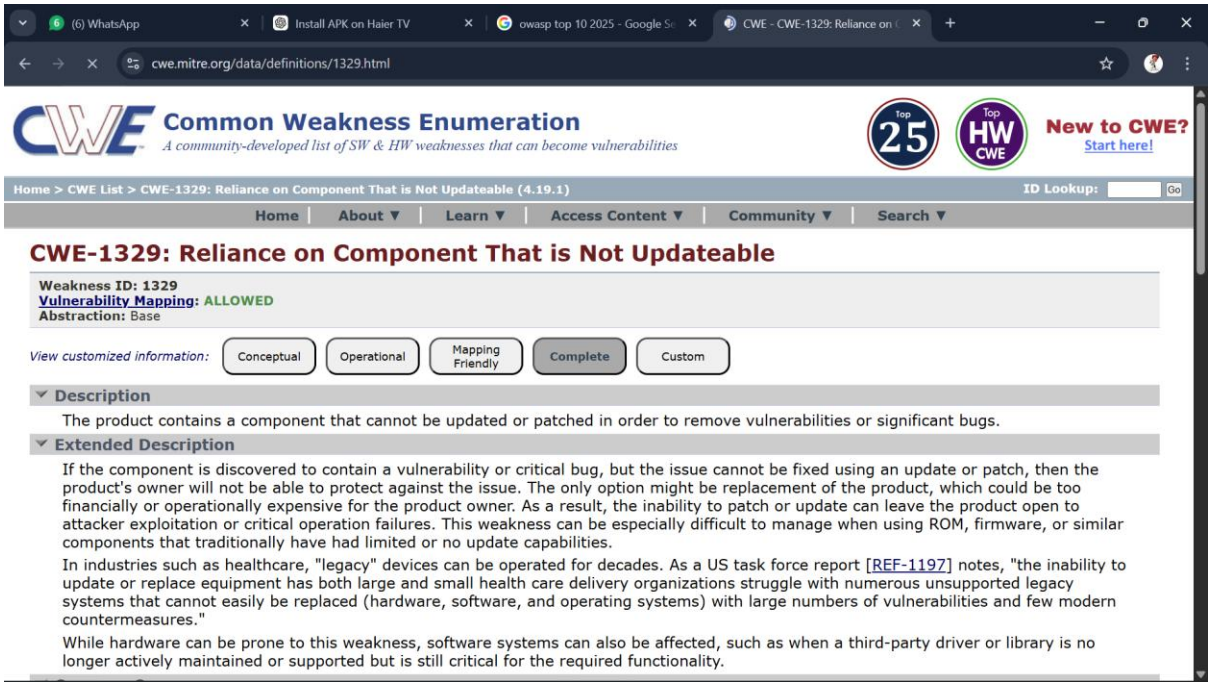
Description:- This vulnerability occurs when an application depends on a software component, library, or third-party dependency that cannot be updated or patched when security issues are discovered. These components may be outdated, unsupported, or hard-coded into the system, making it difficult or impossible to apply security updates.

If vulnerabilities are found in these components, developers cannot easily fix or upgrade them. As a result, the application continues to run with known security weaknesses. Attackers can exploit these weaknesses to compromise the system, gain unauthorized access, or execute malicious code.

This issue commonly occurs when applications rely on deprecated libraries, unsupported frameworks, or third-party software that no longer receives security patches.

Business Impact::- Using components that cannot be updated exposes the organization to long-term security risks. Attackers may exploit known vulnerabilities in outdated or unsupported components to gain unauthorized access to systems, steal sensitive data, or disrupt services.

Because the vulnerable component cannot be patched, the organization may remain exposed to attacks until the system is redesigned or replaced. This can lead to data breaches, financial losses, operational downtime, and damage to the organization's reputation. In addition, failure to maintain secure and updated software components may result in regulatory compliance issues and increased maintenance costs.



4.

Vulnerability Name:- Use of a Key Past its Expiration Date

CWE/CVE : - CWE-324

OWASP/SANS Category:- A04:2025 Cryptographic Failures

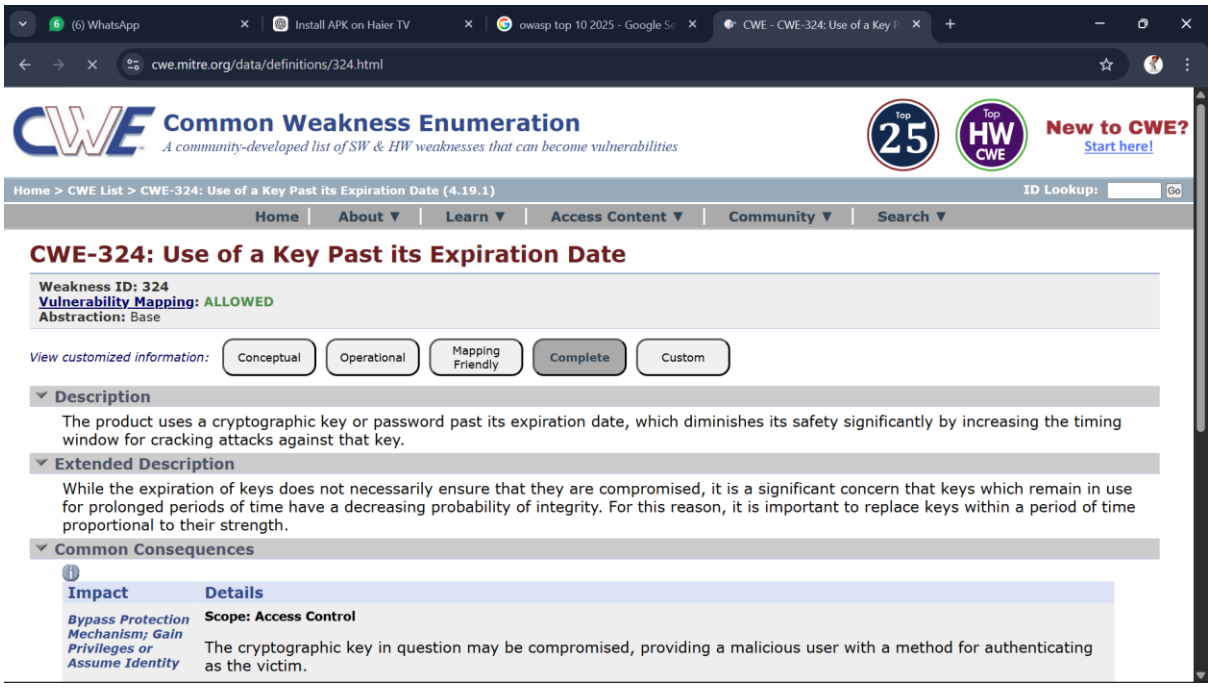
Description:- This vulnerability occurs when an application continues to use a cryptographic key even after its defined expiration date has passed. Cryptographic keys are designed to be used only for a specific period to maintain strong security. After the expiration date, the key should be replaced or rotated with a new one.

If expired keys are still used for encryption, decryption, or authentication processes, the security of the system may be weakened. Older keys may become easier for attackers to compromise due to advancements in attack techniques or potential exposure over time.

Failing to replace expired keys indicates poor cryptographic key management and may allow attackers to exploit the outdated keys to access sensitive information or manipulate secure communications.

Business Impact::- Using expired cryptographic keys increases the risk of unauthorized access and data compromise. Attackers may exploit weakened or outdated keys to decrypt sensitive data, impersonate legitimate users, or tamper with secure communications.

This can lead to exposure of confidential information, loss of data integrity, and unauthorized system access. Such incidents may result in financial losses, operational disruption, regulatory penalties, and damage to the organization's reputation. Proper key management practices are essential to maintain strong security and protect critical business data.



5.

Vulnerability Name:- Improper Control of Resource Identifiers ('Resource Injection')

CWE/CVE : - CWE-99

OWASP/SANS Category:- A05:2025 Injection

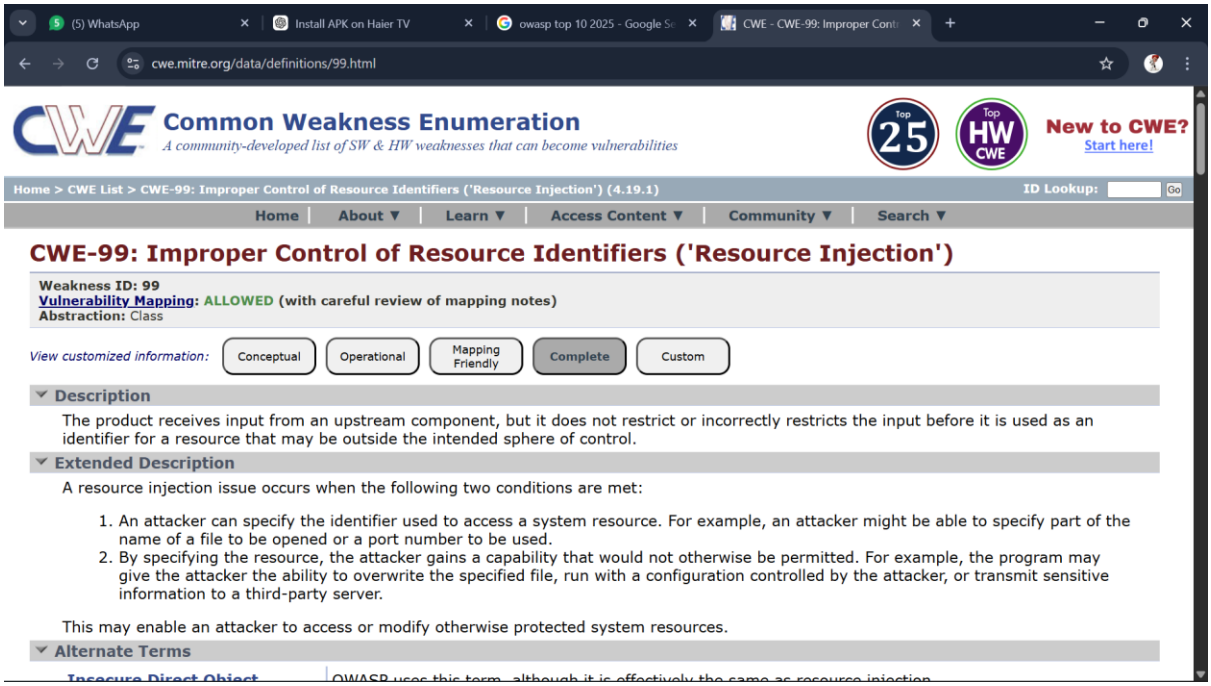
Description:- This vulnerability occurs when an application fails to properly validate or sanitize user-supplied input used to access system resources such as files, URLs, or database resources. If the application directly uses user input as a resource identifier without proper validation, attackers may manipulate the input to access unintended resources.

For example, an attacker may modify parameters in a request to access sensitive files, internal system resources, or unauthorized data. This type of vulnerability can allow attackers to perform unauthorized operations such as loading malicious resources, accessing restricted files, or interacting with backend systems in unintended ways.

Improper control of resource identifiers is often caused by lack of input validation, insecure coding practices, or failure to restrict user input to safe and expected values.

Business Impact::- If exploited, this vulnerability may allow attackers to access sensitive files, internal system resources, or confidential data that should not be publicly accessible. This could lead to data leakage, unauthorized system access, or manipulation of application behavior.

Attackers may also exploit this weakness to execute further attacks against the system, potentially leading to system compromise or service disruption. Such incidents can result in financial losses, damage to the organization's reputation, and potential legal or regulatory consequences if sensitive user or business data is exposed.



6.

Vulnerability Name:- Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CWE/CVE : - CWE-444

OWASP/SANS Category:- A06:2025 Insecure Design

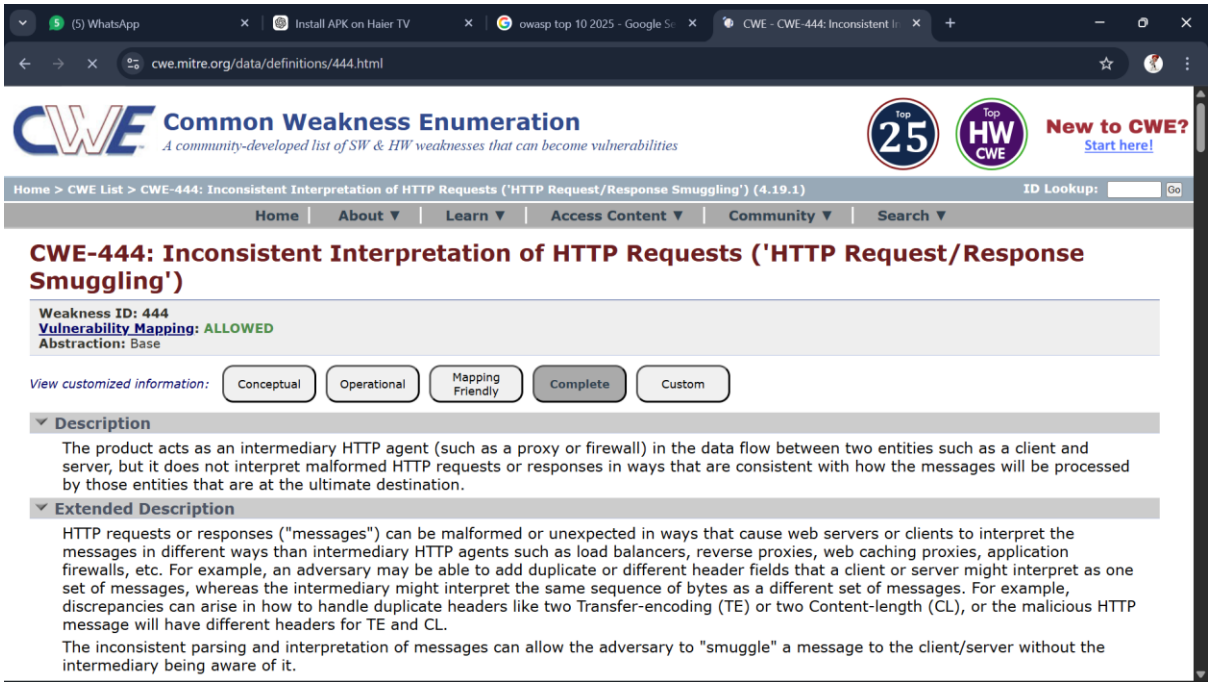
Description:- This vulnerability occurs when different components of a web application infrastructure, such as web servers, reverse proxies, or load balancers, interpret HTTP requests in inconsistent ways. Because of this mismatch in interpretation, attackers can craft specially designed HTTP requests that are processed differently by the front-end server and the back-end server.

For example, attackers may manipulate HTTP headers such as **Content-Length** and **Transfer-Encoding** to create ambiguity in how the request should be handled. This allows attackers to “smuggle” hidden requests inside a legitimate HTTP request. The backend server may then process these hidden requests without proper validation.

As a result, attackers may bypass security controls, manipulate web application behavior, or interfere with other users’ requests. This vulnerability is commonly known as **HTTP Request Smuggling** and occurs due to insecure application design and improper request handling between servers.

Business Impact::- If this vulnerability is exploited, attackers may be able to bypass web security mechanisms such as authentication controls, firewalls, or access restrictions. This can allow unauthorized access to sensitive data or protected application functionality.

Attackers may also manipulate user sessions, perform cache poisoning, steal session tokens, or interfere with other users' requests. These attacks can lead to data breaches, service disruption, and compromise of application integrity. Such incidents may result in financial losses, damage to the organization's reputation, and loss of customer trust.



7.

Vulnerability Name:- Unverified Password Change

CWE/CVE : - CWE-620

OWASP/SANS Category:- A07:2025 Authentication Failures

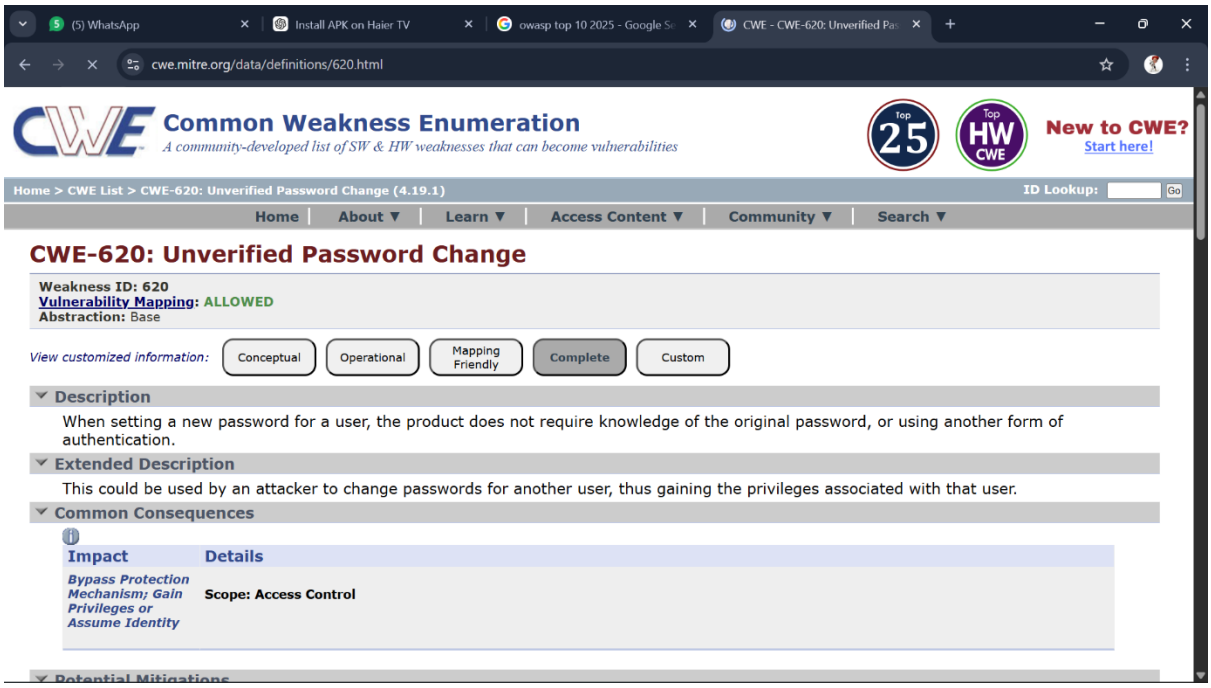
Description:- This vulnerability occurs when an application allows users to change their account password without properly verifying their identity. In a secure system, password changes should require verification steps such as entering the current password, confirming identity through multi-factor authentication, or validating a secure token.

If these verification mechanisms are missing or improperly implemented, an attacker who gains temporary access to a user's account session or manipulates application requests may change the password without the legitimate user's authorization. This lack of proper authentication during the password change process can allow unauthorized users to take control of accounts.

Such vulnerabilities are typically caused by weak authentication design, improper session validation, or missing security checks during sensitive account operations.

Business Impact::- If attackers exploit this vulnerability, they may gain permanent control of user accounts by changing the account password. Once the password is changed, legitimate users may lose access to their accounts, leading to account takeover.

Account takeover can result in unauthorized transactions, data theft, or misuse of user accounts for malicious activities. This can cause financial losses, compromise sensitive user information, and damage the organization's reputation. Additionally, organizations may face regulatory penalties or loss of customer trust if user accounts are compromised due to weak authentication controls.



8.

Vulnerability Name:- Insufficient Verification of Data Authenticity

CWE/CVE : - CWE-345

OWASP/SANS Category:- A08:2025 Software or Data Integrity Failures

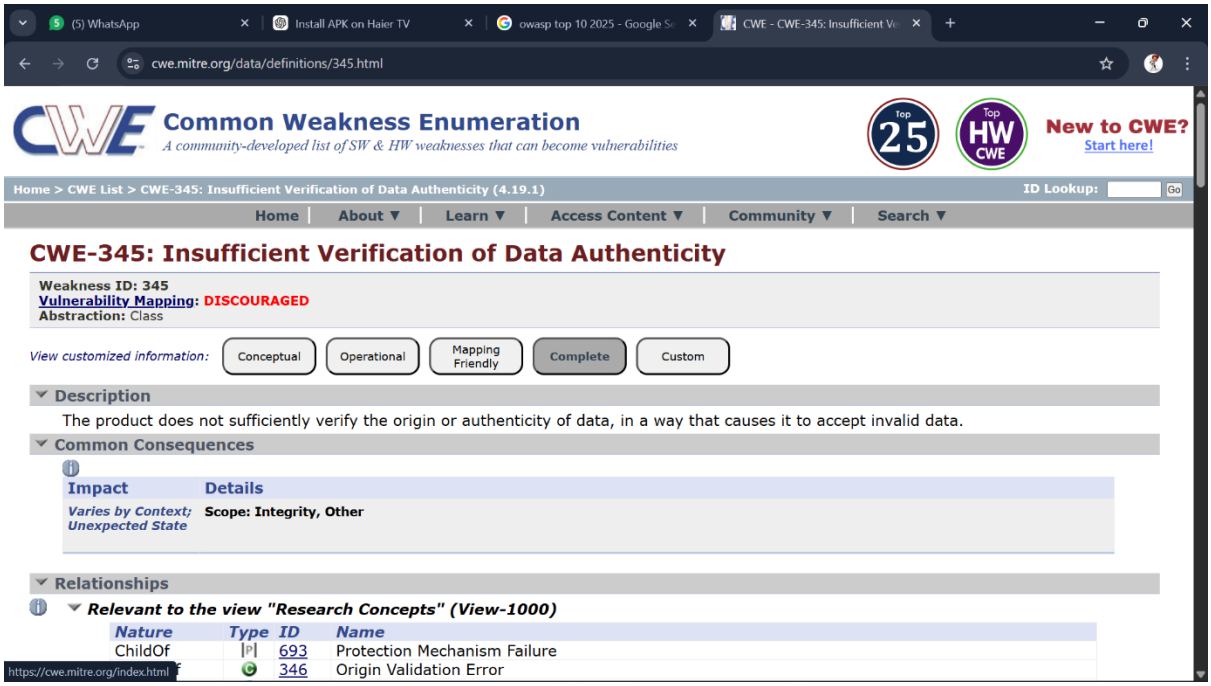
Description:- This vulnerability occurs when an application fails to properly verify the authenticity and integrity of data before processing it. Applications often rely on external data sources such as APIs, software updates, configuration files, or user inputs. If the system does not validate whether the data comes from a trusted source or has been modified, attackers may inject malicious or altered data.

Without proper verification mechanisms such as digital signatures, checksums, or secure validation processes, the application may unknowingly accept and execute tampered or unauthorized data. This can allow attackers to manipulate application behavior, introduce malicious code, or alter critical system information.

Such weaknesses typically arise from poor validation processes, missing integrity checks, or insecure data handling practices.

Business Impact::- If attackers exploit this vulnerability, they may be able to modify or inject malicious data into the system, which could lead to unauthorized actions, system manipulation, or execution of malicious code. This may compromise the integrity of the application and the accuracy of its data.

As a result, the organization may face data corruption, security breaches, service disruption, and loss of trust from users or customers. In severe cases, attackers may gain deeper access to internal systems or distribute compromised software updates, leading to widespread security incidents and potential financial or reputational damage.



9.

Vulnerability Name:- Insufficient Logging

CWE/CVE : - CWE-778

OWASP/SANS Category:- A09:2025 Security Logging & Alerting Failures

Description:- This vulnerability occurs when an application does not generate adequate logs for important security-related events. Security logs are essential for monitoring user activities, detecting suspicious behavior, and identifying potential security incidents. If critical actions such as login attempts, access to sensitive resources, system errors, or

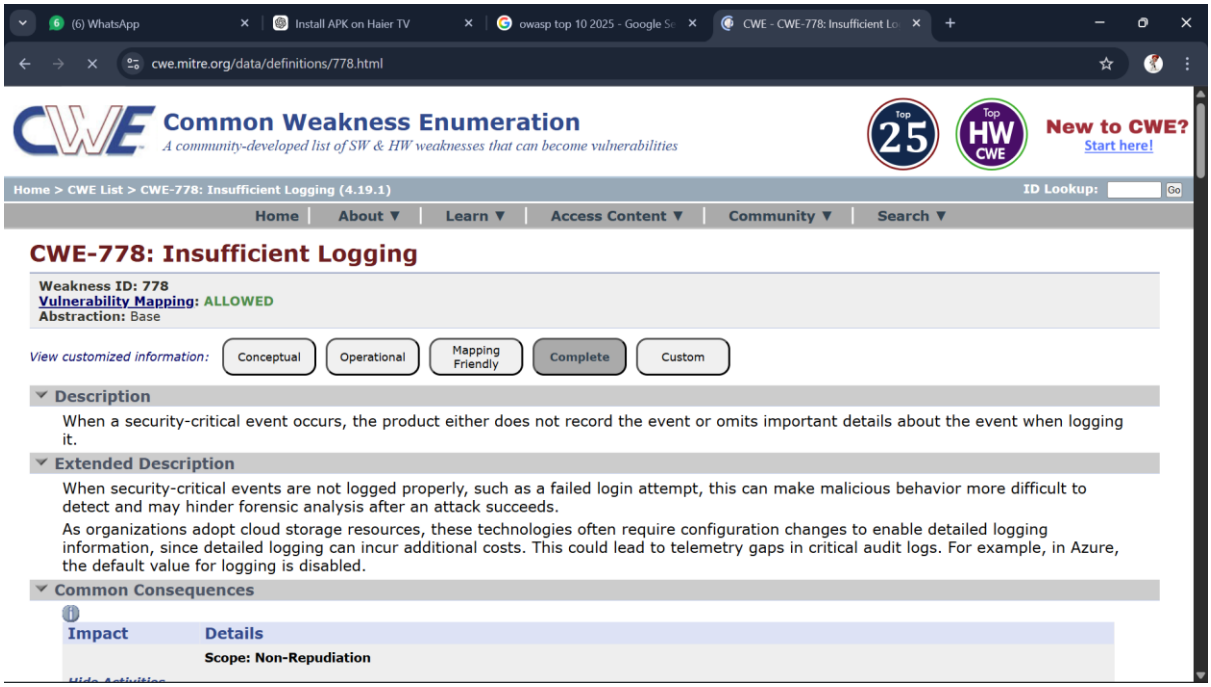
configuration changes are not properly logged, it becomes difficult to track malicious activities.

Without sufficient logging mechanisms, security teams may not be able to detect unauthorized access attempts, system misuse, or ongoing attacks in a timely manner. Additionally, the lack of proper logging makes it difficult to investigate security incidents, perform forensic analysis, or determine the root cause of a breach.

This vulnerability often results from poor logging practices, missing monitoring tools, or improper configuration of logging systems.

Business Impact::- If security events are not properly logged, attackers may be able to perform malicious activities without being detected. Unauthorized access, data manipulation, or system misuse may go unnoticed for long periods of time.

The lack of proper logs also makes incident response and forensic investigation extremely difficult. Organizations may struggle to identify how an attack occurred, what systems were affected, or what data was compromised. This can lead to prolonged security incidents, increased financial losses, operational disruption, and damage to the organization's reputation. Additionally, failure to maintain proper logging may result in non-compliance with security standards and regulatory requirements.



10.

Vulnerability Name:- Divide By Zero

CWE/CVE : - CWE-369

OWASP/SANS Category:- A10:2025 Mishandling of Exceptional Conditions

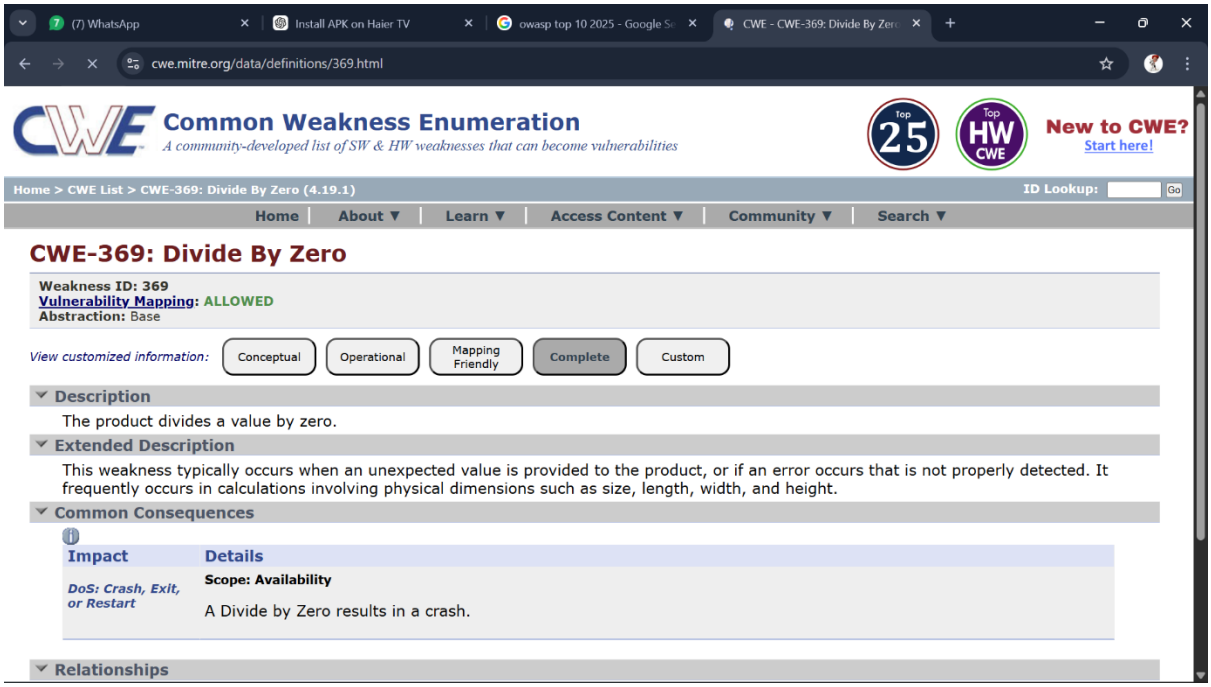
Description:- This vulnerability occurs when an application attempts to divide a number by zero during program execution without properly handling the exception. In many programming languages, dividing a value by zero causes a runtime error or program crash.

If user input or application data is used in mathematical calculations without proper validation, an attacker may intentionally provide a value of zero to trigger this condition. When the application fails to handle this exceptional case properly, it may lead to application errors, unexpected behavior, or system crashes.

This issue generally arises due to insufficient input validation and lack of proper error handling mechanisms within the application logic.

Business Impact::- If this vulnerability is exploited, attackers may cause the application to crash or become unresponsive by triggering a divide-by-zero condition. This can lead to service disruption or denial of service for legitimate users.

Frequent crashes or system instability can affect application availability and reliability. In business environments, this may result in operational downtime, loss of productivity, and potential financial losses. Additionally, repeated failures may damage the organization's reputation and reduce user trust in the system's reliability.



Stage – 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, ope rating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.

2. Nessus sends a series of probes to the target host in order to identify its operating system and services.

3. Nessus runs a series of plugins to test for vulnerabilities.

4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

● Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

● Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.

● Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

● Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.

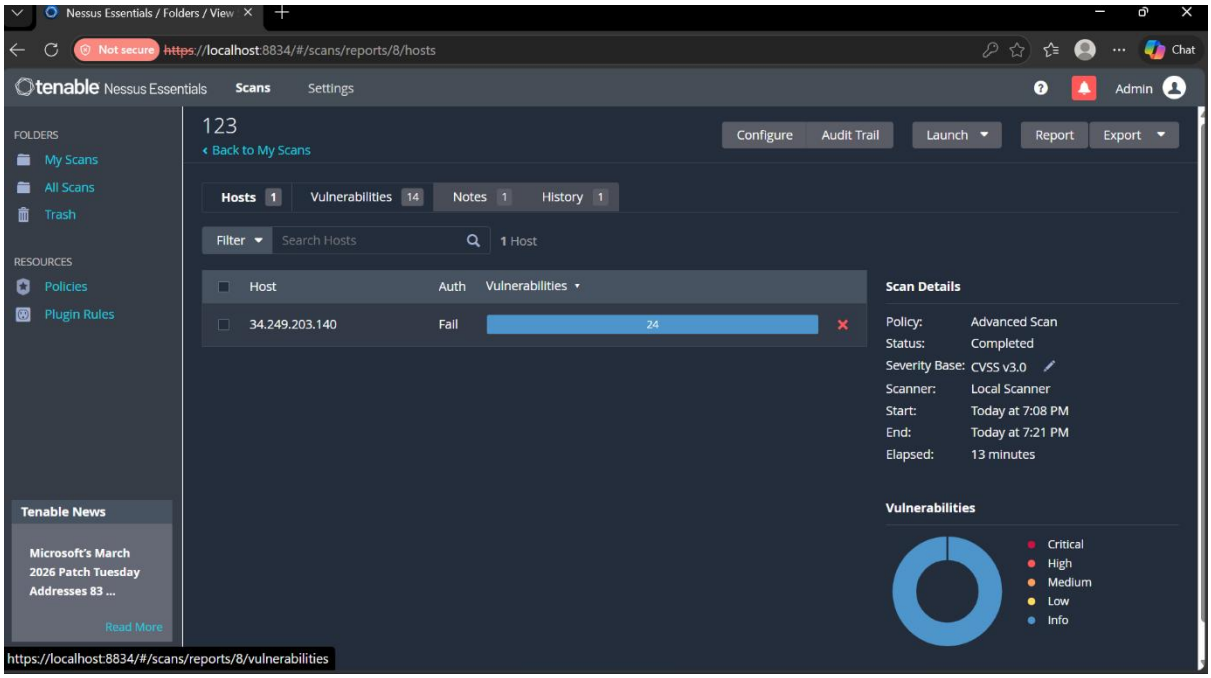
● Flexibility: Nessus can be configured to run scans on a schedule or manually.

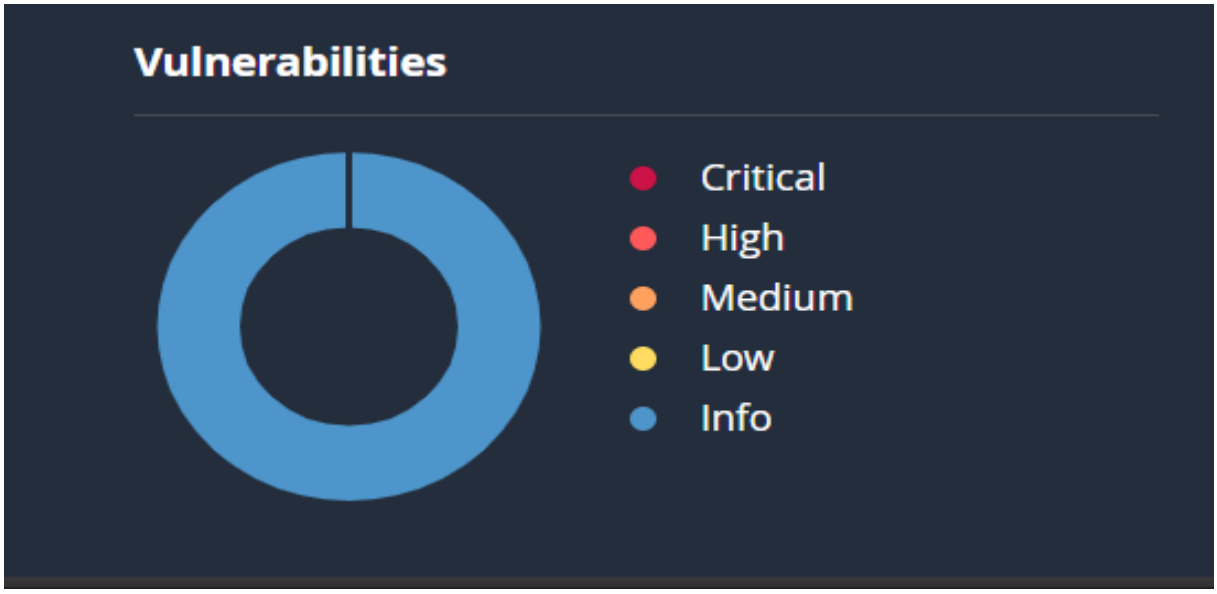
Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

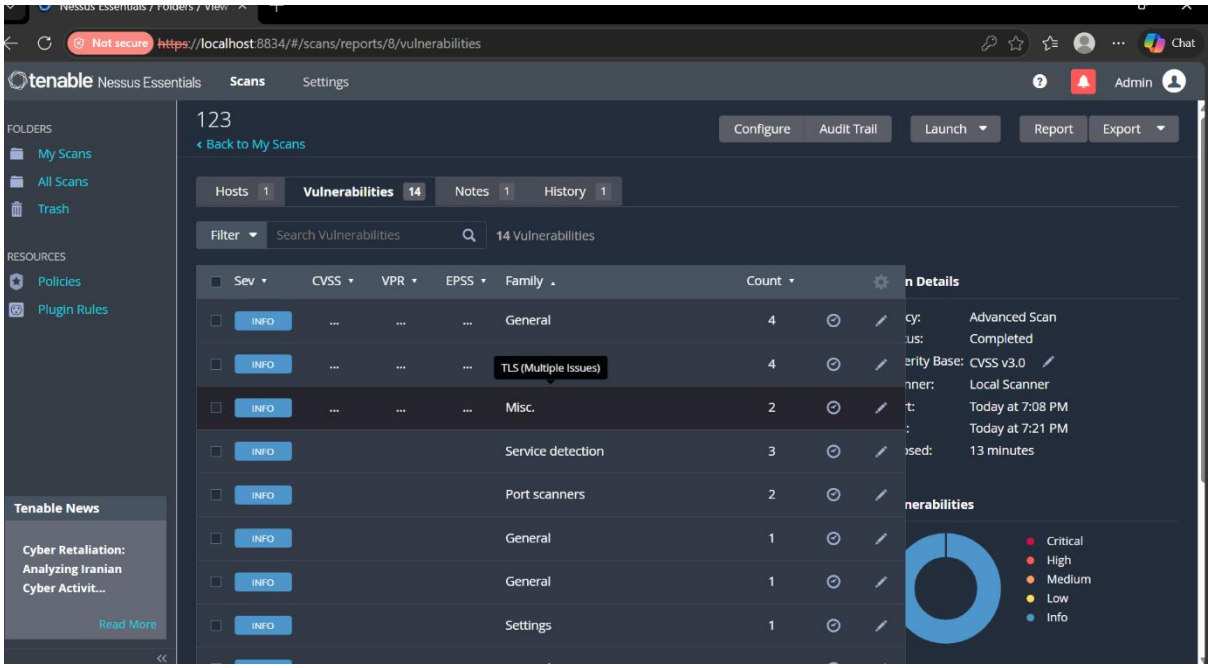
Target website :- http://testfire.net/

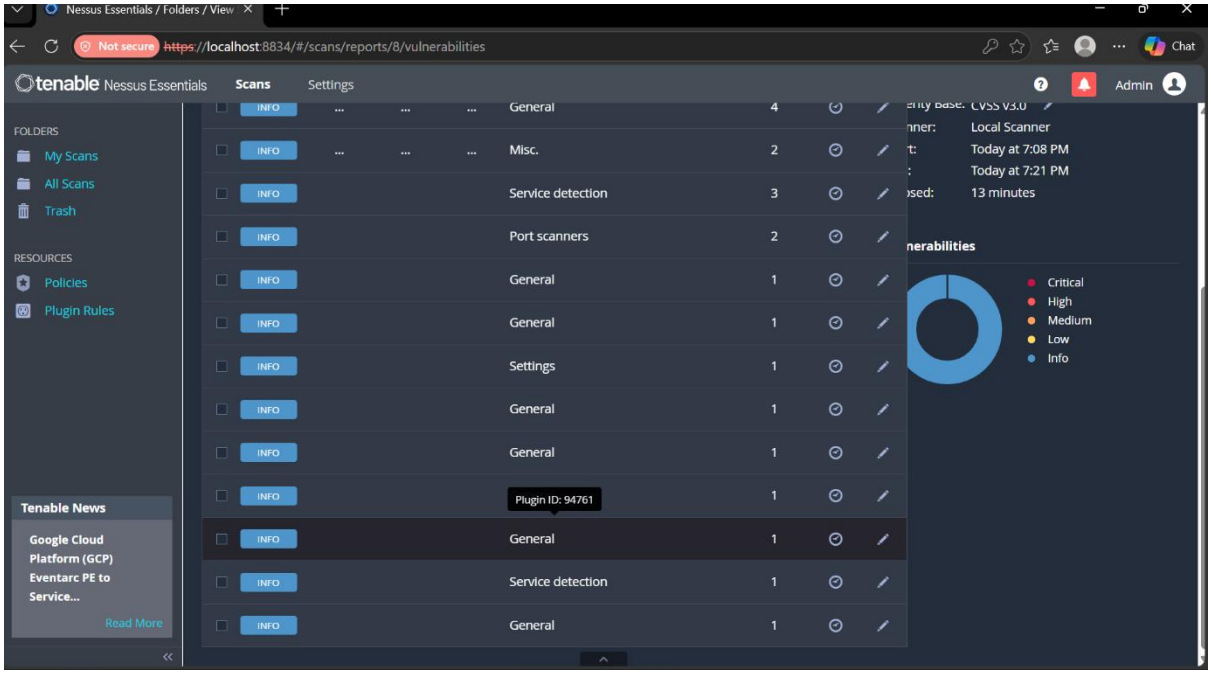
Target IP address:- 65.61.137.117

NESSUS SCAN REPORT:




Vulnerabilities
Critical
High
Medium
Low
Info


Not secure https://localhost:8834/#/scans/reports/8/vulnerabilities
Chat
tenable Nessus Essentials
Scans
Settings
Admin
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Tenable News
Cyber Retaliation: Analyzing Iranian Cyber Activit...
Read More
123
Back to My Scans
Configure
Audit Trail
Launch
Report
Export
Hosts 1
Vulnerabilities 14
Notes 1
History 1
Filter
Search Vulnerabilities
14 Vulnerabilities
Sev
CVSS
VPR
EPSS
Family
Count
INFO
General 4
TLS (Multiple Issues) 4
Misc. 2
Service detection 3
Port scanners 2
General 1
General 1
Settings 1
Advanced Scan
Completed
CVSS v3.0
Local Scanner
Today at 7:08 PM
Today at 7:21 PM
13 minutes
Critical
High
Medium
Low
Info



List of Detected Vulnerabilities with Plugin Family, Severity and Plugin ID:

S.NO	Category of the Plugin(Family)	Severity	Plugins ID
1	Service Detection	Info	22964
2	General	Info	94761
3	Service Detection	Info	136318
4	General	Info	10287
5	General	Info	46180
6	Port Scanners	Info	11219
7	Misc.	Info	84821
8	Settings	Info	19506

REPORT(Stage 2):

01. Category of the Plugin(Family): Service Detection

Severity: Info

Plugin Name(ID): Service detection (22964)

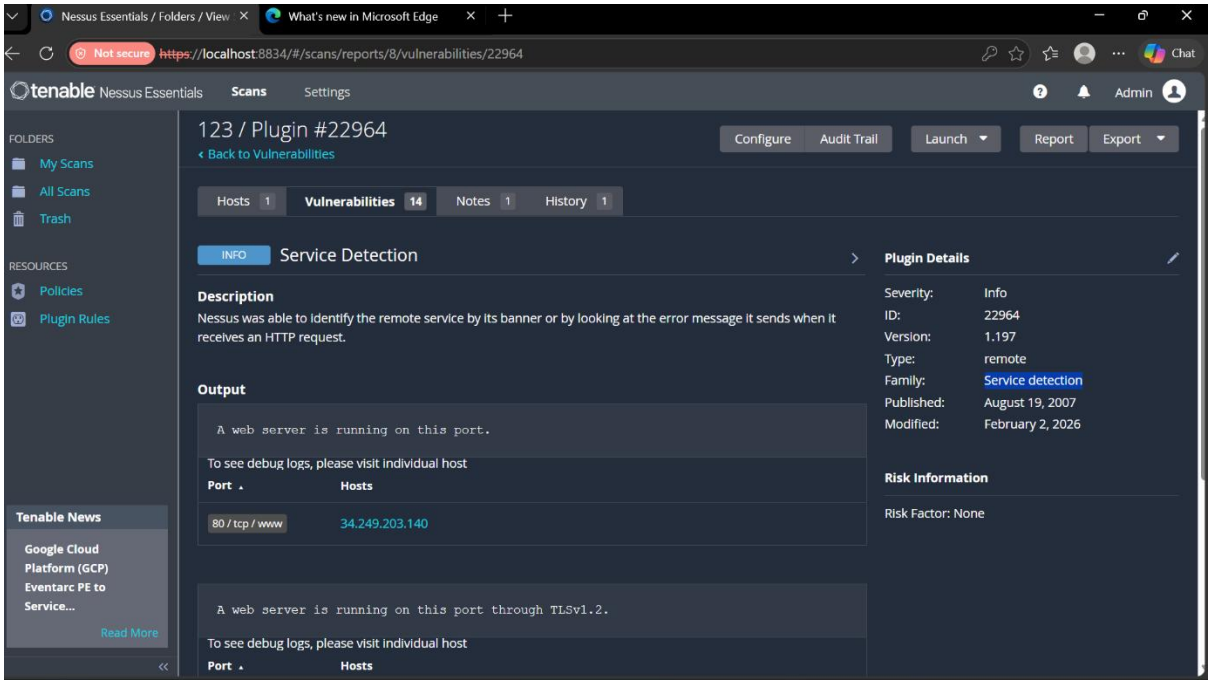
Description: The plugin scans open ports and attempts to identify the service or application running on those ports. This information helps in understanding the system's network exposure and possible attack surface.

Solution: Review the detected services and ensure that only required services are running on the system. Disable or restrict unnecessary services to reduce potential security risks.

Output: The output displays the port number, service name, and protocol detected during the scan. This helps administrators identify which services are active on the host.

Bussiness Impact: Although informational, exposed services may reveal details about the system that attackers could use for reconnaissance. Knowing which services are running helps organizations secure unnecessary or misconfigured services.

OWASP/SANS Category: OWASP Top 10 A09: Security Logging & Monitoring Failures



02. Category of the Plugin(Family): General

Severity: Info

Plugin Name(ID): SSL Root Certification Authority Certificate Information(94761)

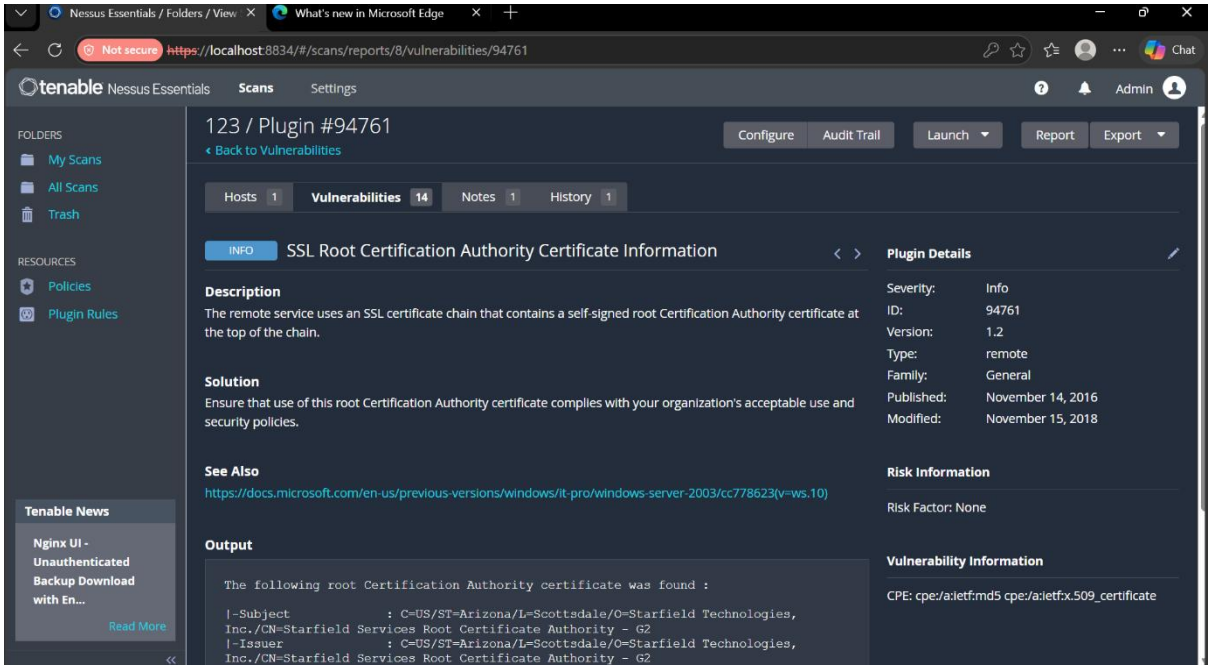
Description: The plugin retrieves and displays information about the root certificate authority involved in the SSL/TLS certificate chain. This information helps administrators verify the authenticity and trust level of the certificate used by the server.

Solution:. No immediate action is required for informational findings. However, administrators should ensure that the certificate is issued by a trusted and valid certificate authority and is properly configured.

Output:. The output typically displays details such as the certificate issuer, certificate authority name, and certificate chain information detected during the scan.

Bussiness Impact: Although informational, certificate details may reveal information about the system's encryption configuration. Proper certificate management ensures secure communication and prevents potential trust or authentication issues.

OWASP/SANS Category: OWASP Top 10 A02: Cryptographic Failures



3.Category of the Plugin(Family): Service Detection

Severity: Info

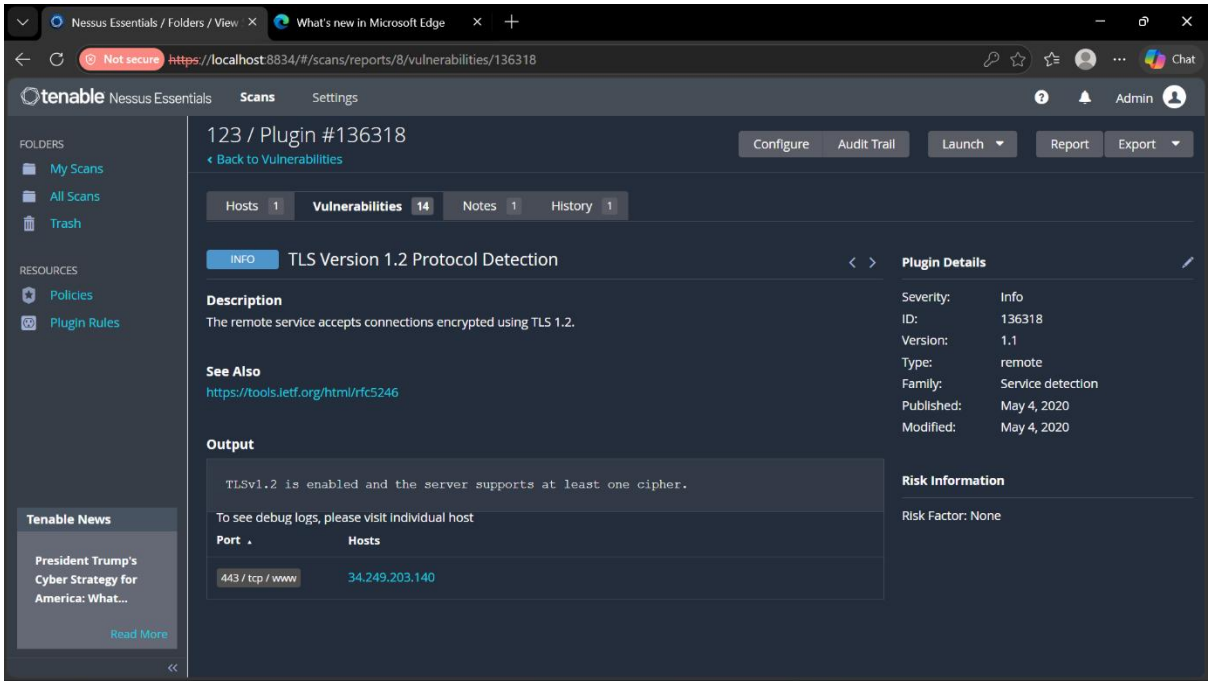
Plugin Name(ID): TLS Version 1.2 Protocol Detection(136318)

Description: The plugin checks the target server to determine if **Transport Layer Security (TLS) version 1.2** is enabled. TLS 1.2 is widely used for secure communication over the internet and helps protect data confidentiality and integrity.

Solution:. No action is required if TLS 1.2 is enabled, as it is considered a secure protocol. However, administrators should ensure that older and insecure protocols like SSL or TLS 1.0 are disabled.

Output:. The output shows the detected TLS protocol version supported by the server, including the port number and service where TLS 1.2 is enabled.

Bussiness Impact: This informational result helps organizations verify that secure encryption protocols are in use. Proper TLS configuration ensures safe data transmission and protects sensitive information during network communication.



4.Category of the Plugin(Family): General

Severity: Info

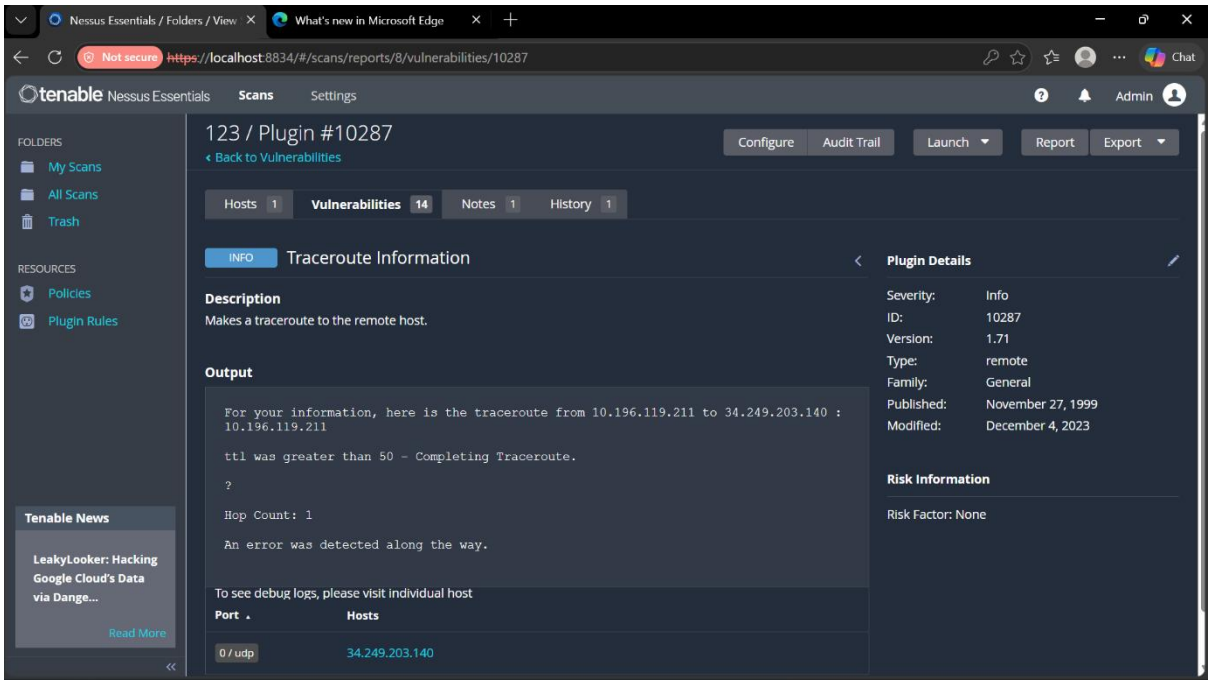
Plugin Name(ID): Traceroute Information(10287)

Description: The plugin collects traceroute data to show how packets travel through the network to reach the target system. This information helps administrators understand the network structure and identify routing points.

Solution:. No direct remediation is required since this is an informational finding. However, administrators should ensure that unnecessary network information is not exposed to unauthorized users.

Output:. The output typically displays the list of network hops, IP addresses, and response times for each device between the scanner and the target system.

Bussiness Impact: Although informational, traceroute data may reveal internal network structure and routing paths. Attackers could potentially use this information for reconnaissance during network attacks.



5.Category of the Plugin(Family): General

Severity: Info

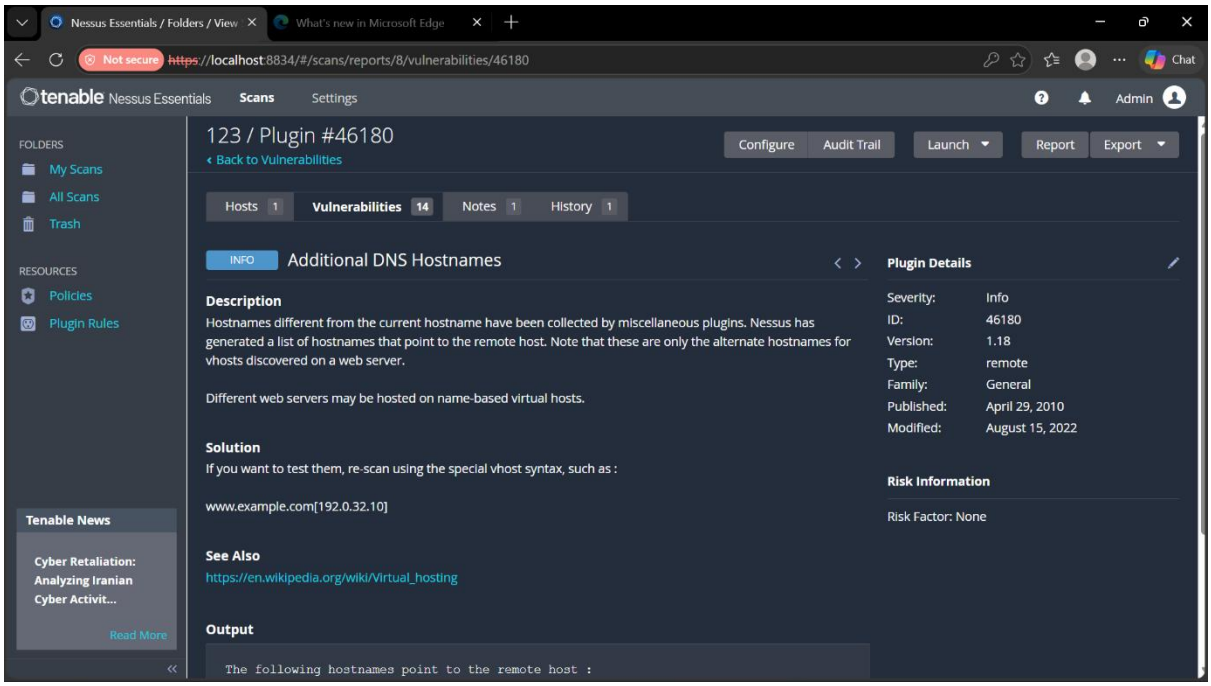
Plugin Name(ID): Additional DNS Hostnames(46180)

Description: The plugin performs DNS lookups to discover alternate hostnames that point to the scanned host. This information helps security analysts understand how the system is referenced within the network or internet.

Solution:. No immediate action is required for informational findings. However, administrators should review the listed hostnames and ensure that only authorized domains are associated with the server.

Output:. The output typically displays a list of additional DNS hostnames or domain names that resolve to the target IP address.

Bussiness Impact: Although informational, exposed DNS hostnames may reveal additional services or domains associated with the organization. Attackers could use this information for reconnaissance or further security analysis



6.Category of the Plugin(Family): Port Scanners

Severity: Info

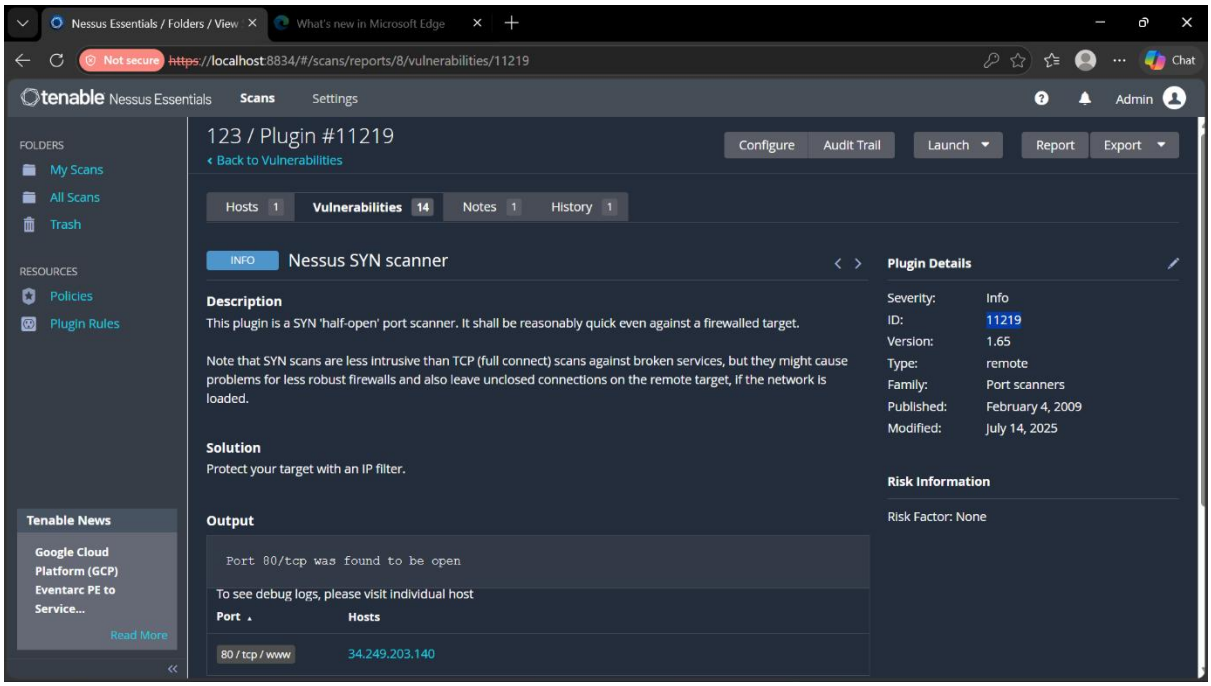
Plugin Name(ID): Nessus SYN scanner(11219)

Description: The plugin uses a half-open scanning technique to identify open TCP ports without completing the full connection. This method helps detect services running on the system while minimizing the impact on the target.

Solution:. No remediation is required since this is an informational scan result. However, administrators should review open ports and close any unnecessary ones to improve system security.

Output:. The output lists the open ports, protocols, and service responses detected during the SYN scan on the target system.

Bussiness Impact: Open ports may expose network services that could be targeted by attackers. Identifying these ports helps organizations reduce the attack surface by disabling unused or unnecessary services.



7.Category of the Plugin(Family): Misc.

Severity: Info

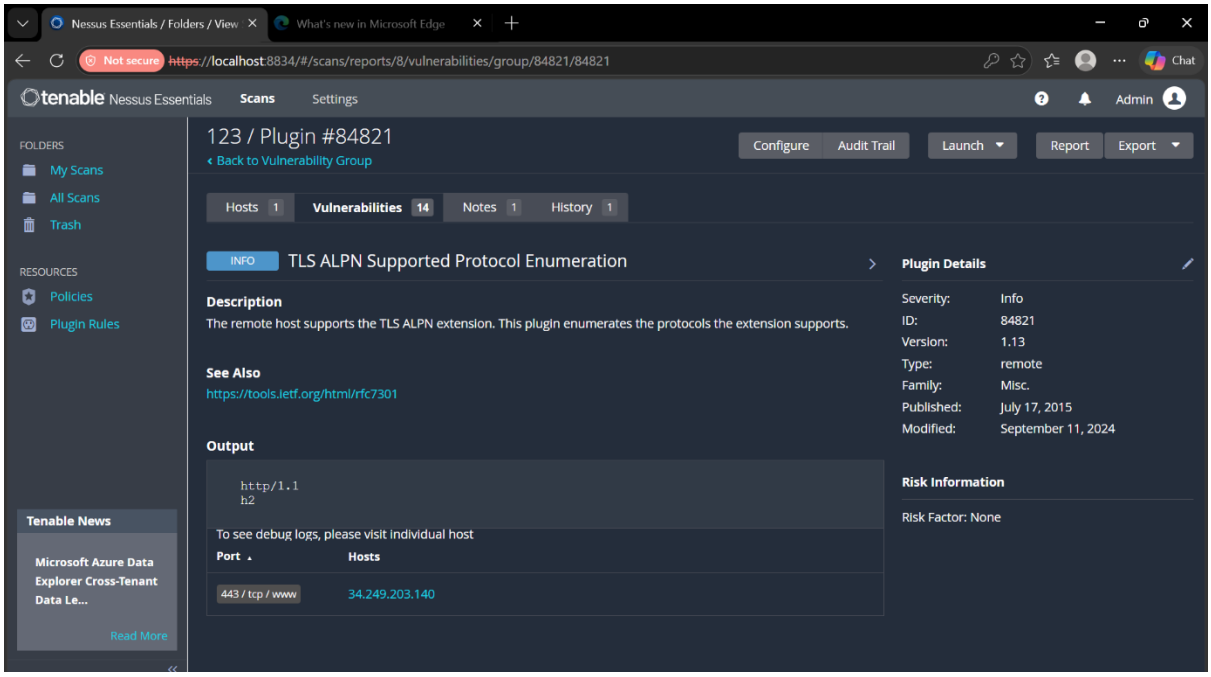
Plugin Name(ID): TLS ALPN Supported Protocol Enumeration(84821)

Description: The plugin checks the TLS handshake process to enumerate supported ALPN protocols such as HTTP/1.1 or HTTP/2. This information helps security analysts understand the communication protocols used by the server.

Solution:. No direct remediation is required for this informational finding. However, administrators should review supported protocols and disable any outdated or unnecessary protocols to maintain secure communication.

Output:. The output lists the ALPN protocols supported by the server during the TLS handshake. It may include protocols like HTTP/1.1, HTTP/2, or other application-level protocols.

Bussiness Impact: Although informational, the disclosed protocol details may provide attackers with information about the server's communication capabilities. Proper configuration helps ensure that only secure and necessary protocols are supported.



8.Category of the Plugin(Family): Settings

Severity: Info

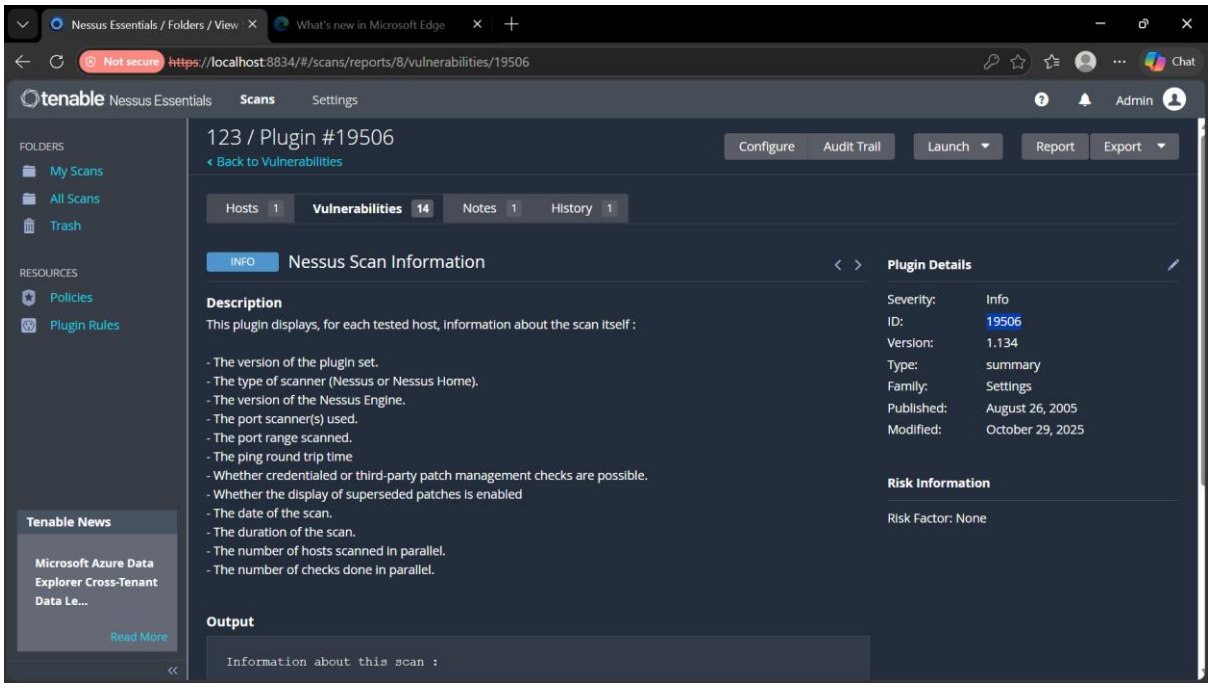
Plugin Name(ID): Nessus Scan Information(19506)

Description: It displays information about the Nessus scan that was performed on the target system. This helps administrators understand the scan environment and settings used.

Solution:. No action is required because it is not a security vulnerability. It is only informational data generated by the scanner.

Output:. The output shows scan details such as Nessus version, scan start time, and plugin feed information. These details help in verifying and documenting the scan.

Bussiness Impact: There is no direct business risk because it is informational only. It helps security teams track and manage vulnerability scanning activities.



Stage – 3

Title of the project:

Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Overview:

Zero Trust Network Access (ZTNA) is a modern security model that replaces traditional network security methods such as VPNs. Instead of trusting users or devices simply because they are inside the corporate network, ZTNA follows the principle of **"never trust, always verify."** This approach ensures that every user, device, and application request is continuously authenticated and authorized before access is granted. By implementing ZTNA, organizations can protect sensitive resources from unauthorized access, cyber threats, and data breaches.

Zscaler is a cloud-based security platform that enables organizations to implement the Zero Trust model effectively. Zscaler's ZTNA solution connects users directly to specific applications instead of the entire network, which significantly reduces the attack surface. This means that users only access the applications they are permitted to use, while the rest of the network remains hidden. Because Zscaler operates through the cloud, it provides secure access for users working from offices, homes, or remote locations without requiring traditional VPN connections.

ZTNA with Zscaler works by verifying multiple factors before granting access to an application. These factors include **user identity, device security posture, application sensitivity, and contextual information** such as location or time of access. Once the verification is completed, a secure connection is established between the user and the specific application. This method ensures that only authorized users with trusted devices can access corporate resources, improving overall security and reducing the risk of cyber attacks.

In modern organizations where remote work and cloud applications are common, ZTNA with Zscaler plays a crucial role in protecting digital infrastructure. It provides **secure, scalable, and efficient user-to-application connectivity** without exposing the internal network to potential threats. By adopting this Zero Trust approach, organizations can enhance their cybersecurity posture while maintaining seamless and secure access for employees, partners, and stakeholders.

Conclusion: -

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In **Stage 1**: understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.

Stage 2: delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures. highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures

Stage 3 :illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration and machine learning, these systems are poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world. In essence, the project not only provided a deep understanding of the current state zero trust using ZSCALER but also offered a glimpse into the exciting future of cybersecurity. Embracing these advancements will be crucial for organisations aiming to fortify their digital landscapes in the face of ever-evolving cyber threats

Future Scope: -

Future of web application testing

The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable.

Here are some of the key trends that are expected to shape the future of WAT:

- Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.

- Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

- Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.

- Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable.

Here are some of the key trends that are expected to shape the future of the testing process:

- Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.

- Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

- Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.

- Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

Future scope of SOC / SEIM:-

The future scope of Zero Trust Network Access (ZTNA) and the broader Zero Trust framework is poised for significant evolution, driven by emerging technologies and changing threat landscapes:

1. **AI-Driven Zero Trust (AI-ZTA):** Future Zero Trust implementations will leverage advanced AI and deep learning to move beyond static policies. Systems will continuously learn user behavior, predict anomalous activities before they occur, and dynamically adjust access privileges in real-time based on contextual risk, creating a truly "adaptive" security posture.
2. **Integration with Edge Computing and IoT:** As organizations deploy more IoT devices and edge computing nodes, Zero Trust principles will extend to these resource-constrained environments. Expect the development of lightweight Zero Trust agents and protocols that can authenticate and secure machine-to-machine (M2M) communication at the edge, preventing large-scale botnet attacks.
3. **Identity-Centric Everything:** The future will see identity become the ultimate security perimeter. Zero Trust will evolve to incorporate advanced identity verification methods, including **continuous behavioral biometrics** (keystroke dynamics, gait analysis) and **decentralized identity** solutions using blockchain, ensuring that the user behind the session is verified at all times.
4. **Zero Trust for Operational Technology (OT) and Critical Infrastructure:** Sectors like energy, manufacturing, and healthcare will increasingly adopt Zero Trust to protect critical infrastructure. Future scope includes air-gapped Zero Trust solutions and specialized protocols designed to secure legacy industrial control systems (ICS) and SCADA environments from nation-state attacks.
5. **Automated Threat Hunting and Response:** Future Zero Trust platforms will integrate with Security Orchestration, Automation, and Response (SOAR) tools to enable automated threat hunting. Upon detecting a compromised identity or device, the system will not just block access but automatically initiate investigation playbooks, isolate affected systems, and even roll back malicious changes.

Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: -

Nessus Scanner, OWASP ZAP

THE END